Universidad Nacional de Ingeniería

Área de Conocimiento de Tecnología de la Información y Comunicación

Auditoria de Sistemas

Elaborado por:

Br. Gerson Antonio Valdivia

Br. Stephanie Lucía Mora Chávez

Br. Haxell Antonio Trejos Rodríguez

Br. Alison Michelle Navarro Goussen

Br. Arleth del Rosario Velásquez Gómez

Docente:

Msc. Leonel Antonio Martínez Zuniga

18 de abril, 2026
Managua, Nicaragua

En grupo de trabajo, se les asignará 2 tipos de auditoría y sobre ello deben de desarrollar lo siguiente:

Auditoría asignada: Base de datos

1. Aspectos que deben de ser evaluados.

Diagnóstico del Entorno

El diagnóstico es el punto de partida para entender qué estamos protegiendo y de qué lo estamos protegiendo.

A. Amenazas

1. **Acceso no autorizado:** Exfiltración de datos por parte de atacantes externos o empleados con privilegios excesivos.
2. **Inyección de Código (SQL Injection):** Manipulación de consultas para saltar la lógica de seguridad.
3. **Denegación de Servicio (DoS):** Sobrecarga de la base de datos para interrumpir la disponibilidad del negocio.
4. **Desastres naturales o fallos de infraestructura:** Pérdida física de los servidores o corrupción de archivos por fallos de energía.

B. Vulnerabilidades

1. **Configuraciones por defecto:** Contraseñas de fábrica o servicios innecesarios activos.
2. **Falta de parches:** Motores de base de datos (DBMS) desactualizados con CVEs (Common Vulnerabilities and Exposures) conocidos.
3. **Cifrado inexistente:** Datos en reposo o en tránsito que viajan en texto plano.
4. **Logs insuficientes:** Falta de trazabilidad sobre quién consultó o modificó tablas críticas.

C. Riesgos

1. **Riesgo de Cumplimiento:** Multas legales por no proteger datos sensibles (ej. GDPR o leyes locales).
2. **Riesgo Reputacional:** Pérdida de confianza del cliente tras una brecha de datos.
3. **Riesgo Operativo:** Incapacidad de operar debido a la corrupción de la integridad de los datos.

2. Criterios, metodologías, estándares, normativas, leyes que deben de ser consideradas.

Categoría	Referencia Profesional
Estándares de Seguridad	ISO/IEC 27001 (SGSI), ISO/IEC 27017 (Nube).
Marcos de Control	COBIT 2019 (Gobierno de TI), NIST SP 800-53.
Mejores Prácticas	CIS Benchmarks (configuraciones específicas para Oracle, SQL Server, MySQL).
Leyes y Regulaciones	GDPR (Europa), Leyes Nacionales de Protección de Datos Personales, PCI-DSS (si maneja tarjetas).
Metodología de Auditoría	ISACA (IT Audit Framework - ITAF).

3. Oferta de auditoría.

Proyecto: Auditoría Integral de Seguridad y Cumplimiento de Base de Datos.

I. Objetivo General

Evaluar la eficacia de los controles de seguridad, integridad y disponibilidad aplicados al motor de base de datos, identificando brechas respecto a las mejores prácticas de la industria.

II. Alcance Técnico

1. **Revisión de Configuración de Seguridad:** Análisis del endurecimiento (*Hardening*) del DBMS.
2. **Gestión de Accesos:** Revisión de roles, privilegios, perfiles de usuario y políticas de contraseñas.
3. **Seguridad de los Datos:** Verificación de mecanismos de cifrado (TDE), enmascaramiento y copias de seguridad.
4. **Auditoría de Eventos:** Evaluación de la configuración de logs y monitoreo de actividad (DAM).

5. **Pruebas de Vulnerabilidades:** Escaneo especializado sobre el motor para detectar fallos de parcheo.

III. Entregables

1. **Informe Ejecutivo:** Resumen de riesgos para la alta dirección.
2. **Informe Técnico Detallado:** Listado de hallazgos con evidencia, nivel de riesgo y recomendaciones de remediación.
3. **Matriz de Seguimiento:** Plan de acción sugerido.

4. Bosquejo de la estructura general del cronograma de auditoría.

Fase 1: Planificación y Reconocimiento (Semana 1)

1. Reunión de apertura (Kick-off).
2. Solicitud de documentación (políticas, inventarios, diagramas de red).
3. Definición de usuarios y accesos temporales para el auditor.

Fase 2: Ejecución y Pruebas de Campo (Semana 2-3)

1. **Entrevistas:** Con administradores de BD (DBAs) y responsables de seguridad.
2. **Revisión Técnica:** Extracción de configuraciones y revisión de scripts.
3. **Pruebas de Cumplimiento:** Verificación de que lo que dicen los manuales se cumple en la realidad.
4. **Análisis de Vulnerabilidades:** Ejecución de herramientas de escaneo.

Fase 3: Análisis de Hallazgos y Borrador (Semana 4)

1. Correlación de datos obtenidos.
2. Clasificación de hallazgos (Crítico, Alto, Medio, Bajo).
3. Redacción del informe preliminar.

Fase 4: Cierre y Entrega (Semana 5)

1. Reunión de validación de hallazgos con el área técnica (para evitar falsos positivos).
2. Presentación final de resultados a la gerencia.
3. Entrega del informe final firmado.

Auditoría asignada: Gestión informática

1. Aspectos que deben de ser evaluados.

A. Amenazas

1. **Ciberataques:** Ransomware, phishing y ataques dirigidos a la infraestructura crítica.
2. **Obsolescencia Tecnológica:** Hardware o software que ya no recibe soporte del fabricante.
3. **Fuga de Información:** Acciones malintencionadas o accidentales de empleados (Insider Threats).
4. **Interrupción del Negocio:** Fallos en el suministro eléctrico, desastres naturales o caídas de proveedores de nube.

B. Vulnerabilidades

1. **Procesos Inexistentes:** Falta de políticas formalizadas para el alta/baja de usuarios o gestión de cambios.
2. **Debilidad en Controles Lógicos:** Contraseñas débiles, falta de doble factor de autenticación (MFA).
3. **Capacidad Limitada:** Personal insuficiente o falta de capacitación técnica especializada.
4. **Ausencia de Respaldo:** Backups no probados o guardados en el mismo sitio que el original.

C. Riesgos

1. **Riesgo Operativo:** Caída de sistemas críticos que detiene la producción o el servicio.
2. **Riesgo Financiero:** Pérdidas económicas por fraudes electrónicos o multas regulatorias.
3. **Riesgo de Integridad:** Modificación no autorizada de registros contables o datos maestros.

2. Criterios, metodologías, estándares, normativas, leyes que deben de ser consideradas.

Categoría	Estándar / Ley	Aplicación en la Gestión Informática
Gobernanza	**COBIT 2019**	Marco principal para el gobierno y gestión de las TI empresariales.
Seguridad	**ISO/IEC 27001**	Estándar para el Sistema de Gestión de Seguridad de la Información (SGSI).
Servicios	**ITIL v4**	Buenas prácticas para la gestión de servicios de TI (SLA, incidentes).
Metodología	**ITAF (ISACA)**	Marco de referencia para la práctica profesional de auditoría de TI.
Legal	**GDPR / Leyes Locales**	Cumplimiento de protección de datos personales y privacidad.

3. Oferta de auditoría.

I. Objetivo General

Evaluar la madurez de los controles de TI, la alineación de la tecnología con la estrategia institucional y la eficacia de los mecanismos de seguridad y continuidad.

II. Alcance (Dominios a Auditar)

1. **Gobierno de TI:** Estructura organizacional, roles y responsabilidades.
2. **Gestión de Operaciones:** Monitorización de sistemas, gestión de capacidad y mantenimiento.
3. **Seguridad Física y Lógica:** Control de acceso a centros de datos y sistemas de información.
4. **Continuidad del Negocio (BCP/DRP):** Evaluación de planes de recuperación ante desastres.

5. **Gestión de Proyectos y Cambios:** Control sobre el desarrollo y paso a producción de software.

III. Metodología de Trabajo

Se utilizará un enfoque de tres fases: **Planificación**, **Ejecución (Pruebas de cumplimiento y sustantivas)** y **Comunicación de Resultados**.

4. Bosquejo de la estructura general del cronograma de auditoría.

Fase 1: Planificación (Semana 1)

1. **Reunión de Apertura:** Definición de interlocutores y logística.
2. **Entendimiento del Negocio:** Entrevistas iniciales y revisión de organigramas.
3. **Plan de Auditoría:** Firma de la matriz de riesgos y programa de trabajo.

Fase 2: Trabajo de Campo / Ejecución (Semanas 2-4)

1. **Pruebas de Control:** Verificación de logs, revisión de configuraciones y políticas.
2. **Inspección Física:** Visita al centro de cómputo y áreas de soporte.
3. **Recolección de Evidencias:** Capturas de pantalla, reportes de sistema y actas.
4. **Identificación de Hallazgos:** Registro de desviaciones encontradas.

Fase 3: Informe y Cierre (Semana 5)

1. **Validación de Hallazgos:** Discusión técnica con los dueños de los procesos para evitar errores de interpretación.
2. **Informe Preliminar:** Envío del borrador para comentarios de la gerencia.
3. **Informe Final:** Presentación de resultados finales con recomendaciones y plan de remediación sugerido.
4. **Reunión de Cierre:** Entrega formal del dictamen de auditoría.